

TP 03 – Preguntas y Respuestas

1 1. Para pensar

Alguien cambia un precio sin permiso. ¿Qué principio se afecta más?

El principio que se ve vulnerado de manera directa es la Integridad.

En la teoría de la seguridad de la información, la integridad garantiza que los activos de datos permanezcan exactos, completos, autenticados y no alterados sin la debida autorización explícita durante su almacenamiento, procesamiento o transmisión.

La modificación no autorizada de la matriz de precios compromete la validez de la información del catálogo comercial, distorsionando la lógica de negocio y afectando la consistencia de las transacciones financieras. Aunque la confidencialidad (exposición indeseada) o la disponibilidad (interrupción del servicio) pudiesen permanecer intactas, la falta de exactitud en los datos destruye la confianza transaccional y puede generar pérdidas económicas severas o responsabilidad legal ante el consumidor.

Clasificá PC, mouse, navegador y aplicación de ventas como hardware o software. Elegí un dispositivo de entrada y explicá qué dato permite ingresar.

Hardware (Componentes Físicos/Tangibles):

- PC (Personal Computer): Unidad de procesamiento y almacenamiento físico local.
- Mouse: Periférico físico de entrada e interacción.

Software (Componentes Lógicos/Intangibles):

- Navegador Web: Software cliente que interpreta código (HTML/JS) y gestiona peticiones mediante protocolos de red (HTTP/HTTPS).
- Aplicación de Ventas: Sistema de software lógicamente estructurado (SaaS o aplicación web) encargado de la lógica transaccional del negocio.

Selección del Dispositivo de Entrada (Mouse):

El mouse es un periférico de entrada que permite ingresar eventos de interfaz de usuario mediante coordenadas vectoriales x/y, clics e instrucciones de selección interactiva. En el contexto de la tienda, permite al operador seleccionar productos, confirmar órdenes de compra o interactuar con los módulos de administración de la plataforma.

Dibujá el recorrido cliente → Internet → servidor de la tienda. Explicá para qué sirve HTTPS. ¿Qué es una máquina virtual y por qué puede servir para probar cambios?

Diagrama de Flujo de Red:

[Dispositivo Cliente] → [Router Local / ISP] → [Red Pública / Internet] → [Firewall / Router Perimetral] → [Servidor Web en la Nube]

Función del Protocolo HTTPS (Hypertext Transfer Protocol Secure):

HTTPS es un protocolo de capa de aplicación que encapsula el tráfico HTTP estándar sobre un canal cifrado mediante TLS/SSL (Transport Layer Security). Proporciona tres controles de seguridad esenciales:

- Confidencialidad: Cifra los datos transmitidos (credenciales, números de tarjetas, pedidos) impidiendo la interceptación por ataques de intermediario (Man-in-the-Middle).
- Integridad: Emplea códigos de autenticación de mensajes (HMAC) para asegurar que la información no sea alterada en tránsito.
- Autenticación del Servidor: Utiliza certificados digitales emitidos por una Autoridad Certificadora (CA) para validar la identidad legítima del servidor de la tienda frente al cliente.

Máquina Virtual (VM) y Entornos de Prueba:

Una Máquina Virtual es una representación por software de una computadora física que ejecuta un sistema operativo y aplicaciones de forma aislada sobre un programa hipervisor. En la gestión de cambios, permite crear un entorno de pruebas (Staging/Sandbox) réplica de producción. Esto posibilita probar actualizaciones de software, parches o modificaciones de código sin comprometer la disponibilidad ni exponer vulnerabilidades en el entorno comercial en vivo.

Esquema de Conexión de Red y Entorno de Pruebas (VM)

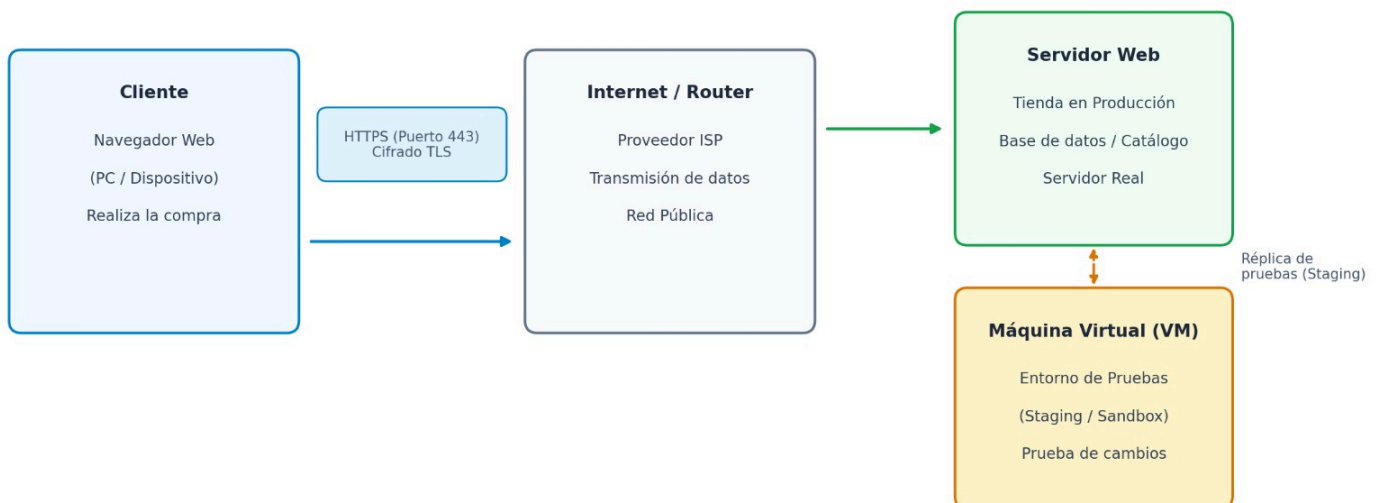


Diagrama de arquitectura: El tráfico viaja cifrado por HTTPS y los cambios se prueban aislados en la VM.

Elegí tres activos entre pedidos, cuentas, web y cámara. Para cada uno, escribí qué pasaría si se pierde o deja de funcionar. ¿Qué dato de clientes evitarías compartir con una IA?

Análisis de Impacto sobre Activos:

- Pedidos (Base de Datos Transaccional): Su pérdida o corrupción invalida la logística de despacho, genera imposibilidad de facturación, reclamos contractuales y pérdida de trazabilidad comercial.
- Cuentas (Credenciales de Acceso e Identidades): Su compromiso o pérdida de control permite ataques de apoderamiento de cuenta (Account Takeover - ATO), elevación no autorizada de privilegios y filtración masiva de bases de datos de usuarios.
- Plataforma Web (Servicio E-commerce): Su caída o indisponibilidad genera una denegación directa del servicio comercial, interrumpiendo el flujo de ingresos en tiempo real y dañando la reputación institucional.

Tratamiento de Datos Sensibles frente a la Inteligencia Artificial:

Se debe evitar estrictamente compartir Datos de Identificación Personal (PII) y Datos Financieros Sensibles (e.g., números de tarjetas de crédito/débito - PAN, códigos de seguridad CVV, contraseñas en texto claro, documentos de identidad y direcciones físicas). La introducción de PII en modelos de IA no auditados viola principios de privacidad (como GDPR o normativas locales de protección de datos) y expone la información a fugas en el entrenamiento o almacenamiento en servidores de terceros.

Un mensaje dice: "Cambiamos la cuenta de cobro. Transferí ahora y no llames al contacto de siempre". Marcá dos señales sospechosas y escribí cómo lo verificarías.

Identificación de Indicadores de Compromiso (IoC) / Señales de Alerta:

1. Urgencia Artificial y Coacción Emocional: La exigencia de transferir "ahora mismo" busca obnubilar el juicio analítico del operador y forzar el salto de los procedimientos administrativos de control.
2. Evasión de Canales de Verificación Oficiales: La instrucción explícita de "no llamar al contacto de siempre" es una técnica típica de ataques de compromiso de correo corporativo (Business Email Compromise - BEC), diseñada para evitar que se descubra el fraude mediante un control cruzado.

Procedimiento de Verificación:

Se debe ejecutar un protocolo de Verificación Fuera de Banda (Out-Of-Band Verification - OOB). Esto consiste en contactar al proveedor de pagos a través de un canal secundario previamente validado y registrado en los contratos oficiales (e.g., llamada al conmutador central o verificación presencial), sin utilizar jamás los enlaces, correos ni números telefónicos provistos en el mensaje sospechoso.

Todos pueden cambiar los precios y la impresora imprime lento. Elegí el problema de seguridad más importante y proponé una solución sencilla.

Evaluación de Prioridad:

El problema crítico de seguridad es que "todos pueden cambiar los precios". Esto constituye una vulnerabilidad grave en la capa de autorización por ausencia del Principio de Menor Privilegio, permitiendo que cualquier usuario (o un atacante que comprometa una cuenta básica) altere la integridad del catálogo de ventas. La lentitud de la impresora representa un mero inconveniente operativo de bajo impacto en la ciberseguridad.

Solución Propuesta:

Implementar un esquema de Control de Acceso Basado en Roles (RBAC - Role-Based Access Control). Bajo este modelo, se restringen los permisos de edición de precios exclusivamente a cuentas con el rol de "Administrador/Gerente de Ventas", requiriendo autenticación reforzada y generando registros de auditoría (logs) por cada modificación realizada.

Un SGSI ayuda a organizar la seguridad. Escribí tres reglas: quién cambia precios, cómo se cuidan las cuentas y cómo se avisa un problema. Indicá quién las revisa.

Un Sistema de Gestión de Seguridad de la Información (SGSI) formaliza el marco normativo de la organización:

1. Política de Modificación de Precios (Autorización e Integridad): Queda prohibida la alteración de precios por personal no autorizado. Solo el rol de "Administrador de Ventas" posee privilegios de escritura en el módulo de tarifas, previa aprobación formal.
2. Política de Credenciales e Identidad (Autenticación): Todas las cuentas de usuario deben ser nominativas e individuales. Queda estrictamente prohibido compartir contraseñas. Es obligatorio el uso de contraseñas robustas y Autenticación Multi-Factor (MFA).
3. Política de Gestión de Incidentes: Todo evento anómalo, falla técnica o sospecha de ataque de ingeniería social debe ser reportado inmediatamente al canal oficial de TI/Seguridad mediante un formulario o correo de incidentes.

Responsable de Supervisión:

El Oficial de Seguridad de la Información (CISO) o el Administrador del SGSI, mediante auditorías periódicas de cumplimiento.

Un reporte de Nessus u OpenVAS dice "software de la tienda sin actualizar". ¿Qué revisarías antes de actualizar? Escribí una forma de comprobar después que todavía se pueden registrar pedidos.

Acciones Previas a la Actualización (Gestión de Cambios):

Antes de aplicar un parche, se debe revisar la compatibilidad del nuevo software con las dependencias existentes, consultar las notas de lanzamiento (Release Notes) del fabricante para evaluar parches de seguridad vs. cambios críticos, y ejecutar una copia de seguridad/snapshot integral de la base de datos y la aplicación. Asimismo, la actualización debe ensayarse primero en el entorno virtualizado de pruebas (Staging).

Prueba Funcional Posterior (Smoke Testing / E2E Testing):

Para verificar la operatividad post-parche, se ejecuta una prueba de transacción de extremo a extremo (End-to-End). Se simula un pedido de prueba (utilizando un usuario de testeo y credenciales de pasarela en modo Sandbox), confirmando que el pedido se inserte correctamente en la base de datos, el pago sea procesado y se genere la notificación de confirmación sin errores en los registros del servidor.

Los clientes usan la misma WiFi que la PC de ventas. Proponé una separación sencilla. Elegí firewall o MFA y explicá cómo ayudaría a proteger las cuentas o la red.

Propuesta de Segmentación de Red:

Configurar una Red de Invitados (Guest Network) aislada lógicamente mediante VLANs (Virtual Local Area Network) en el router/Access Point. Esto separa físicamente o lógicamente el tráfico no confiable de los clientes del segmento de red corporativo donde opera la PC de ventas.

Selección y Explicación del Mecanismo (Firewall vs. MFA):

- Firewall (Protección de Red): Actúa como una barrera de filtrado de paquetes entre la red de clientes y la red interna. Permite definir reglas explícitas de control de acceso (Deny All por defecto), bloqueando cualquier intento de escaneo, comunicación o tráfico entrante desde los dispositivos de los clientes hacia las direcciones IP y puertos de la PC de ventas o de la infraestructura de pago.
- MFA (Protección de Identidad): Si se selecciona MFA (Multi-Factor Authentication), este mecanismo exige al menos dos factores de verificación independientes (e.g., contraseña + token TOTP dinámico en dispositivo móvil) para iniciar sesión en las cuentas administrativas. Incluso si un atacante en la red WiFi lograra interceptar una contraseña en texto plano, no podría acceder al sistema sin el segundo factor físico.

Datos simulados: Nmap muestra 443 open y 21 closed; Wireshark registra una consulta DNS antes de entrar a la tienda. Identificá el puerto cerrado y explicá qué ayuda a resolver DNS.

Interpretación de Hallazgos de Nmap:

- Puerto 443 (Open / Abierto): Servicio HTTPS activo escuchando peticiones web cifradas.
- Puerto 21 (Closed / Cerrado): Corresponde al servicio FTP (File Transfer Protocol). Que figure como "cerrado" significa que el servidor recibió la sonda de exploración de Nmap y respondió expresamente que no hay ningún servicio FTP escuchando en ese puerto en ese momento.

Funcionamiento del Protocolo DNS (Domain Name System):

El protocolo DNS es el servicio encargado de la resolución de nombres de dominio en direcciones IP. Traduce nombres alfanuméricos comprensibles por humanos (ej. www.tiendaenlinea.com) a direcciones IP numéricas ruteables en la Capa 3 del modelo OSI (ej. 190.210.12.5), permitiendo que el navegador del cliente sepa a qué dirección de red exacta debe dirigir la solicitud de conexión HTTPS.

¿Esto confirma que hay un ataque?

No. Que el puerto 443 esté abierto y que se vea una consulta DNS solo indica funcionamiento normal de la web. Para hablar de ataque habría que ver comportamientos extraños (escaneos, intentos de login fallidos, tráfico hacia IPs sospechosas, etc.).

